Alumno:

Héctor Ulises Cacho González

Docente:

José Miguel Carrera Pacheco

Materia:

Desarrollo Web Profesional

Actividad:

[ACT] S - 9. | Arquitectura de autenticación y control de roles

FECHA:

08 de marzo de 2026

Investigación sobre Autenticación y Autorización

¿Qué es autenticación y en qué se diferencia de autorización?

La autenticación es el proceso mediante el cual un sistema verifica la identidad de un usuario. Es decir, se asegura de que la persona que intenta acceder realmente es quien dice ser. Para realizar esta verificación normalmente se utilizan credenciales como nombre de usuario y contraseña, códigos enviados al teléfono, huellas digitales o reconocimiento facial.

Por ejemplo, cuando una persona inicia sesión en una página web introduciendo su correo electrónico y contraseña, el sistema revisa si esos datos coinciden con los registrados en la base de datos. Si coinciden, el usuario queda autenticado y puede entrar al sistema.

Por otro lado, la autorización ocurre después de la autenticación y consiste en determinar qué acciones puede realizar el usuario dentro del sistema. Es decir, aunque el sistema ya sabe quién es el usuario, todavía debe decidir a qué recursos puede acceder.

Un ejemplo sencillo es el siguiente: un administrador de un sistema puede crear o eliminar usuarios, mientras que un usuario normal solo puede ver su propio perfil. Ambos están autenticados, pero tienen diferentes permisos.

¿Qué son JWT, sesiones y OAuth?

JWT (JSON Web Token)

Los JWT son un tipo de token que se utiliza para transmitir información de forma segura entre dos partes, generalmente entre un servidor y un cliente. Este token contiene información codificada sobre el usuario, como su identificador o permisos, y se firma digitalmente para evitar que sea modificado.

Cuando un usuario inicia sesión correctamente, el servidor genera un JWT y lo envía al cliente. Posteriormente, cada vez que el usuario hace una petición al servidor, envía el token para demostrar que ya está autenticado.

Los JWT son muy utilizados en APIs y aplicaciones modernas, especialmente en aplicaciones móviles y arquitecturas basadas en microservicios.

Sesiones

Las sesiones son un método tradicional de autenticación donde el servidor guarda la información del usuario en memoria o en una base de datos. Cuando el usuario inicia sesión, el servidor crea una sesión y envía al navegador un identificador de sesión almacenado normalmente en una cookie.

Cada vez que el usuario realiza una petición, el navegador envía esa cookie y el servidor identifica al usuario mediante el identificador de sesión.

Este método es común en aplicaciones web tradicionales donde el servidor mantiene el control completo del estado del usuario.

OAuth

OAuth es un protocolo de autorización que permite a los usuarios iniciar sesión en una aplicación utilizando cuentas de otros servicios sin compartir su contraseña.

Por ejemplo, cuando una aplicación permite iniciar sesión con una cuenta de Google o Facebook, generalmente está utilizando OAuth. En este proceso, el usuario se autentica en el proveedor externo y la aplicación recibe un token que confirma la identidad del usuario.

OAuth es ampliamente utilizado para integración entre plataformas y servicios externos.

¿Cuándo conviene usar tokens y cuándo sesiones?

La elección entre tokens y sesiones depende del tipo de aplicación que se esté desarrollando.

Las sesiones suelen utilizarse en aplicaciones web tradicionales donde el servidor mantiene el estado del usuario. Son más sencillas de implementar y permiten invalidar sesiones fácilmente desde el servidor.

Los tokens, como los JWT, se utilizan principalmente en aplicaciones modernas que utilizan APIs, aplicaciones móviles o arquitecturas distribuidas. En este caso, el servidor no necesita almacenar el estado del usuario porque la información se encuentra dentro del propio token.

En general:

- Las sesiones son más adecuadas para aplicaciones web tradicionales con un solo servidor.
- Los tokens son más útiles para aplicaciones distribuidas, APIs REST y sistemas que necesitan escalabilidad.

¿Qué riesgos de seguridad existen en un mal diseño de autenticación?

Un sistema de autenticación mal diseñado puede provocar diversos problemas de seguridad que permiten a los atacantes acceder a información sensible o tomar control de cuentas de usuario.

Uno de los riesgos más comunes es el robo de credenciales, que ocurre cuando las contraseñas no se almacenan de forma segura o se transmiten sin cifrado. Esto puede permitir que un atacante obtenga acceso a cuentas legítimas.

Otro riesgo importante es el secuestro de sesión, donde un atacante obtiene el identificador de sesión de un usuario autenticado y lo utiliza para acceder al sistema sin conocer la contraseña.

También puede ocurrir el problema de fuerza bruta, donde un atacante intenta múltiples combinaciones de contraseñas hasta encontrar la correcta. Si el sistema no tiene mecanismos de protección como límites de intentos o bloqueo temporal, este tipo de ataque puede tener éxito.

Además, el uso incorrecto de tokens puede provocar que estos sean robados o reutilizados si no tienen expiración o si se almacenan en lugares inseguros.

Por estas razones es fundamental aplicar buenas prácticas como cifrado, uso de HTTPS, expiración de tokens y autenticación multifactor.

¿Cómo se definen roles y permisos en sistemas reales?

En los sistemas informáticos reales, los roles y permisos se utilizan para controlar el acceso a los recursos y funcionalidades del sistema.

Un rol representa un conjunto de responsabilidades o funciones dentro del sistema. Por ejemplo, algunos roles comunes son administrador, editor y usuario.

Los permisos son acciones específicas que un usuario puede realizar, como crear registros, modificar información, eliminar datos o ver ciertos contenidos.

En muchos sistemas se utiliza un modelo llamado control de acceso basado en roles (RBAC). En este modelo, a cada rol se le asigna un conjunto de permisos y luego los usuarios reciben uno o varios roles.

Por ejemplo:

- Administrador: puede crear, modificar y eliminar usuarios.
- Editor: puede crear y modificar contenido.
- Usuario: solo puede visualizar contenido.

Este enfoque facilita la administración de permisos y permite mantener un sistema más organizado y seguro.

Bibliografía

Kurose, J., & Ross, K. (2017). *Redes de computadoras: Un enfoque descendente*. Pearson.

Stallings, W. (2018). *Seguridad informática: Principios y práctica*. Pearson Educación.

OWASP Foundation. (2023). *Guía de autenticación y gestión de sesiones*. Disponible en: https://owasp.org

Auth0. (2023). *Introducción a JSON Web Tokens (JWT)*. Disponible en: https://auth0.com

Cloudflare. (2023). *Qué es OAuth y cómo funciona*. Disponible en: https://www.cloudflare.com